

CLOUD SECURITY

AND CLOUD COMPLIANCE

Practical Manager and Junior Analyst Manual

What this manual does: Explains secure cloud governance, architecture, identity, networks, data, workloads, applications, Kubernetes, SaaS, monitoring, resilience, evidence testing, CSA CCM v4.1, open-source tools, management decisions, and job-ready analyst work.

Alberto (Al) Leiva

First Edition • July 2026

Preface

Cloud computing changes who operates technology, how quickly resources appear, and where security responsibilities meet. It does not remove accountability. A secure provider can still have an insecure customer tenant, identity design, application, data flow, integration, or configuration.

This manual is provider-neutral and uses plain language. It is not legal advice, a guarantee, or a substitute for provider documentation. Cloud services, features, threats, prices, contracts, regions, standards, and configuration guidance change quickly. Confirm current official sources and use qualified cloud, security, privacy, legal, architecture, engineering, audit, and business professionals for real decisions.

Current-information note: Verified July 14, 2026. CSA Cloud Controls Matrix v4.1 is the latest CCM/CAIQ release, issued January 2026, with 207 control objectives across 17 domains. Current CISA SCuBA resources, NIST cloud guidance, CIS Benchmarks, and provider-neutral practices are incorporated.

How to use this manual

- Managers: begin with Chapters 1–5, 17–25, and 27.
- Junior analysts: study in order, complete Chapters 26 and 28–29, and use the templates.
- Cloud engineers: focus on Chapters 4–16 and 19–20.
- GRC and assessors: focus on Chapters 2–5 and 21–24.
- Tailor every control and test to the selected provider, service, region, architecture, data, and customer responsibility.

Table of Contents

This document contains a native Word table of contents and a permanent page-numbered chapter guide.

Preface.....	2
How to use this manual.....	2
Table of Contents	3
Chapter Guide	7
1. Cloud Security Foundations	8
1.1 NIST essential characteristics.....	8
2. Service Models and Shared Responsibility	9
2.1 Responsibility matrix	9
3. Cloud Governance, Strategy, and Risk Appetite	10
3.1 Program elements.....	10
4. Inventory, Accounts, Subscriptions, and Ownership.....	11
4.1 Inventory.....	11
4.2 Reconciliation.....	11
5. Secure Architecture and Landing Zones.....	12
5.1 Architecture principles	12
6. Identity and Privileged Access	13
6.1 Human identity	13
6.2 Workload identity	13
7. Network and Connectivity Security	14
7.1 Network controls.....	14
8. Data Security and Privacy.....	15
8.1 Data controls	15
9. Encryption, Keys, Certificates, and Secrets.....	16
9.1 Key management	16
9.2 Secrets and certificates.....	16
10. Logging, Monitoring, and Detection.....	17
10.1 Logging design	17
10.2 Evidence limitations	17
11. Vulnerability, Patch, and Exposure Management.....	18
11.1 Continuous exposure management	18

12. Compute, Storage, Database, and Endpoint Security	19
13. Application Security and DevSecOps	20
13.1 Secure delivery	20
14. Infrastructure as Code and Policy as Code	21
14.1 IaC controls	21
14.2 Policy as code	21
15. Containers and Kubernetes	22
15.1 Cluster controls	22
16. Serverless, APIs, and Event-Driven Services	23
16.1 Serverless controls	23
16.2 API security	23
17. SaaS Security and Business Applications	24
17.1 SaaS review	24
18. Multi-Cloud, Hybrid Cloud, and Portability	25
18.1 Common challenges	25
18.2 Strategy	25
19. Resilience, Backup, and Disaster Recovery	26
19.1 Resilience design	26
20. Cloud Incident Response and Forensics	27
20.1 Prepare	27
20.2 Respond	27
21. Privacy, Legal, Contract, and Data Residency	28
21.1 Privacy and legal review	28
22. CSA Cloud Controls Matrix v4.1 Domains	29
22.1 How to use CCM and CAIQ	29
23. Cloud Assurance and Provider Evidence	30
24. Assessment, Evidence Testing, and Metrics	31
24.1 Test method	31
25. AI Services and Emerging Cloud Risk	32
25.1 AI cloud assessment	32
26. Open-Source Tools	33
26.1 Prowler	33
26.2 ScoutSuite	33
26.3 Steampipe	34

26.4 Cloud Custodian	34
26.5 Checkov	34
26.6 Trivy	34
26.7 tfsec	34
26.8 Terrascan.....	35
26.9 OpenTofu.....	35
26.10 Open Policy Agent	35
26.11 Kyverno.....	35
26.12 kube-bench.....	35
26.13 kube-hunter	36
26.14 Falco	36
26.15 Gitleaks	36
26.16 TruffleHog	36
26.17 Wazuh	37
26.18 DefectDojo.....	37
27. Manager's Cloud Security Playbook.....	38
27.1 Operating rhythm	38
28. Junior Analyst Career Guide	39
28.1 Common roles	39
28.2 Typical work	39
29. Fictional Laboratory, Thirty-Day Plan, and Interview Preparation	40
29.1 Portfolio lab	40
29.2 Thirty-day plan	40
29.3 What is shared responsibility?	40
29.4 IaaS versus PaaS versus SaaS?	41
29.5 Why is identity critical in cloud?	41
29.6 What is a landing zone?	41
29.7 CSPM scan versus assessment?	41
29.8 What is infrastructure as code?.....	41
29.9 How do you secure secrets?	41
29.10 How do you verify cloud recovery?.....	41
29.11 What is CSA CCM v4.1?	41
29.12 What makes a good junior analyst?	41
30. Templates, Glossary, Index, and References	42

30.1 Cloud inventory and responsibility record.....	42
30.2 Cloud control workpaper	42
30.3 Provider assurance review	42
30.4 Incident and recovery record.....	42
30.5 Glossary	43
30.6 Subject index	43
30.7 Official references.....	44

Chapter Guide

Chapter	Title	Starts on page
1	Cloud Security Foundations	5
2	Service Models and Shared Responsibility	6
3	Cloud Governance, Strategy, and Risk Appetite	7
4	Inventory, Accounts, Subscriptions, and Ownership	8
5	Secure Architecture and Landing Zones	9
6	Identity and Privileged Access	10
7	Network and Connectivity Security	11
8	Data Security and Privacy	12
9	Encryption, Keys, Certificates, and Secrets	13
10	Logging, Monitoring, and Detection	14
11	Vulnerability, Patch, and Exposure Management	15
12	Compute, Storage, Database, and Endpoint Security	16
13	Application Security and DevSecOps	17
14	Infrastructure as Code and Policy as Code	18
15	Containers and Kubernetes	19
16	Serverless, APIs, and Event-Driven Services	20
17	SaaS Security and Business Applications	21
18	Multi-Cloud, Hybrid Cloud, and Portability	22
19	Resilience, Backup, and Disaster Recovery	23
20	Cloud Incident Response and Forensics	24
21	Privacy, Legal, Contract, and Data Residency	26
22	CSA Cloud Controls Matrix v4.1 Domains	27
23	Cloud Assurance and Provider Evidence	28
24	Assessment, Evidence Testing, and Metrics	29
25	AI Services and Emerging Cloud Risk	31
26	Open-Source Tools	32
27	Manager's Cloud Security Playbook	37
28	Junior Analyst Career Guide	38
29	Fictional Laboratory, Thirty-Day Plan, and Interview Preparation	40
30	Templates, Glossary, Index, and References	43

1. Cloud Security Foundations

Cloud security protects rapidly changing shared technology, identities, data, applications, and services.

1.1 NIST essential characteristics

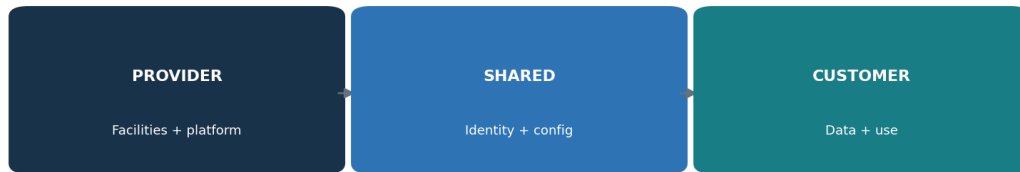
- On-demand self-service: consumers can provision resources without manual provider interaction.
- Broad network access: capabilities are available over networks through standard mechanisms.
- Resource pooling: provider resources serve multiple consumers with location independence at an abstraction level.
- Rapid elasticity: resources can scale quickly and may appear unlimited.
- Measured service: use is monitored, controlled, and reported.

Deployment	Plain meaning	Security focus
Public cloud	Provider infrastructure shared across customers with logical isolation	Tenant configuration, identity, data, provider assurance
Private cloud	Cloud capability dedicated to one organization	Organization operates more infrastructure responsibility
Community cloud	Shared by organizations with common needs	Joint governance, membership, common requirements
Hybrid cloud	Connected distinct cloud environments	Identity, data, network, policy, monitoring, portability

Cloud does not equal secure by default: Speed, automation, managed services, and resilient infrastructure can improve security, but mistakes also scale quickly. Governance and guardrails must move at cloud speed.

2. Service Models and Shared Responsibility

The provider and customer divide responsibility differently in IaaS, PaaS, and SaaS.



Responsibility changes by service model, provider, feature, and contract

Figure 1. Shared-responsibility model

Model	Provider generally operates	Customer generally operates
IaaS	Facilities, physical hardware, core virtualization and service infrastructure	OS/workload, configurations, identities, networks, applications, data, monitoring
PaaS	IaaS plus managed runtime/platform components	Application, identity, data, service configuration, integration, logging
SaaS	Application platform and underlying infrastructure	Users, roles, tenant settings, data choices, integrations, endpoints, monitoring
FaaS/serverless	Infrastructure and managed execution runtime	Code, dependencies, permissions, events, secrets, data, configuration, observability

2.1 Responsibility matrix

- For every control, name provider, customer, shared portion, evidence source, contract reference, assessor, incident duty, and change/exit responsibility.
- A provider report may cover infrastructure while the customer must test tenant configuration and use.
- Managed does not mean unowned; the customer still chooses settings, identities, data, integrations, and acceptable risk.

3. Cloud Governance, Strategy, and Risk Appetite

Governance sets allowed cloud use, ownership, architecture, guardrails, risk, and escalation.

3.1 Program elements

- Cloud strategy, policy, approved providers/services/regions, prohibited uses, data rules, and exception process.
- Cloud center of excellence or equivalent cross-functional ownership across security, platform, architecture, finance, privacy, procurement, legal, and business teams.
- Account/subscription/project hierarchy, landing-zone standards, identity federation, network model, logging, key management, naming/tagging, and baseline controls.
- Risk appetite and mandatory escalation for public exposure, sensitive data, privileged access, unsupported services, concentration, and legal restrictions.
- Provider due diligence, contracts, shared-responsibility records, assurance, monitoring, incident coordination, portability, and exit.
- Metrics, continuous improvement, training, cost/security coordination, and technical debt management.

Role	Accountability
Executive sponsor	Direction, resources, material risk, provider concentration
Cloud platform team	Landing zones, shared services, guardrails, operations
Workload owner	Business purpose, data, configuration, risk, recovery, cost
Security / GRC	Requirements, architecture review, monitoring, assessment, findings
Identity team	Federation, MFA, privilege, service identities, lifecycle
Privacy / legal / procurement	Data roles, residency, contract, rights, provider terms
FinOps	Cost visibility, ownership, waste, commitment and risk tradeoffs
Internal audit / assessor	Objective testing, evidence, limitations, reporting

4. Inventory, Accounts, Subscriptions, and Ownership

Unknown cloud resources cannot be governed, protected, monitored, or retired.

4.1 Inventory

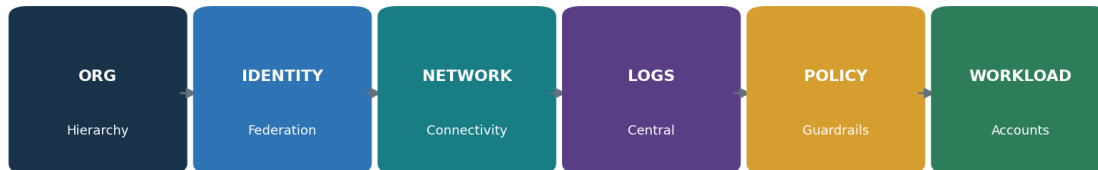
- Organizations/tenants, management groups/folders, accounts/subscriptions/projects, regions, resource owners, business purpose, environments, and billing links.
- Services, resources, images, containers, functions, databases, storage, networks, identities, policies, keys, secrets, certificates, domains, logs, integrations, and providers.
- Data categories, residency, retention, exposure, encryption, backup, recovery, and sharing.
- Public endpoints, privileged paths, cross-account trust, third-party access, unmanaged SaaS, and shadow cloud.
- Tags/labels for owner, application, environment, data class, cost, criticality, recovery tier, expiration, and compliance scope.

4.2 Reconciliation

- Compare cloud provider APIs with CMDB, IaC repositories, identity, DNS, network, procurement, finance, vulnerability, and monitoring sources.
- Investigate orphaned, untagged, unknown, duplicate, inactive, unapproved, and publicly exposed resources.
- Automate discovery but keep accountable owner review and decommission evidence.

5. Secure Architecture and Landing Zones

Landing zones provide safe reusable foundations before workloads arrive.



A landing zone creates reusable governance and security foundations

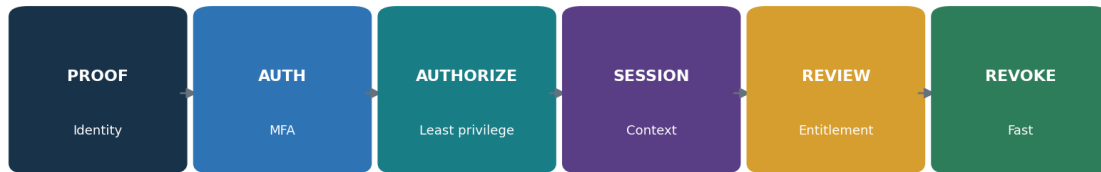
Figure 2. Landing-zone foundation

5.1 Architecture principles

- Separate production, nonproduction, security, logging, networking, shared services, and sandbox environments according to risk.
- Centralize identity federation, emergency access, audit logging, security monitoring, DNS, connectivity, policy, and approved images where appropriate.
- Use deny/guardrail policies for dangerous configurations and preventive controls for high-risk actions.
- Design failure domains, regions/zones, quotas, capacity, service limits, and recovery from BIA requirements.
- Document trust boundaries, administrative paths, data flows, provider services, third parties, and customer/provider responsibilities.
- Deploy landing-zone and workload configuration through reviewed version-controlled code.

6. Identity and Privileged Access

Cloud control planes make identity, tokens, roles, and service principals critical assets.



Cloud identity is the primary control plane and attack path

Figure 3. Cloud identity life cycle

6.1 Human identity

- Federate to an authoritative identity provider; avoid unmanaged cloud-local identities except in controlled emergencies.
- Require phishing-resistant MFA where risk warrants, especially administrators and sensitive actions.
- Use role-based/attribute-based access, just-in-time privilege, approval, short sessions, and separate admin identities.
- Control guest, contractor, support, break-glass, recovery, and provider access.
- Review entitlements, inactive accounts, toxic combinations, cross-account trust, and actual use.

6.2 Workload identity

- Prefer short-lived workload identity and managed identity over embedded static keys.
- Scope permissions to exact resources/actions and separate build, deploy, runtime, and support identities.
- Inventory owners, purpose, credentials, last use, rotation, trust policy, and dependent services.
- Detect new privilege, federation, key creation, consent, impersonation, and unusual token use.

7. Network and Connectivity Security

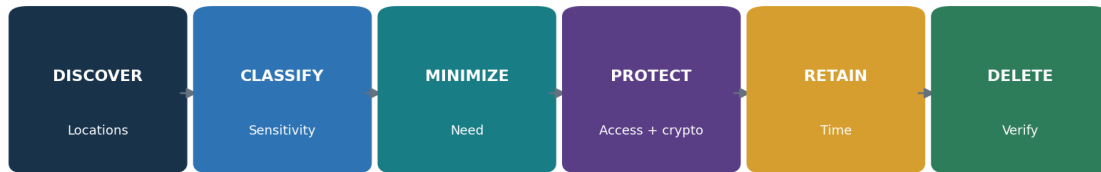
Cloud networks combine provider constructs, internet exposure, private connectivity, and application-layer controls.

7.1 Network controls

- Document virtual networks, subnets, routing, gateways, peering, private endpoints, load balancers, firewalls, proxies, DNS, service endpoints, and on-premises links.
- Default deny where practical; restrict management interfaces and use controlled administrative paths.
- Segment by trust, environment, application, data, and blast radius; prevent accidental transitive routing.
- Use application-aware protection, DDoS controls, web application firewalls, API gateways, egress restrictions, and DNS security according to risk.
- Encrypt traffic, validate certificates, protect private connectivity, and monitor flow/DNS/proxy/application records.
- Continuously find public IPs, open rules, permissive security groups, exposed storage/databases, and shadow tunnels.

8. Data Security and Privacy

Cloud data security begins with purpose, location, classification, and minimization.



Cloud data security follows information through its full life cycle

Figure 4. Cloud data life cycle

8.1 Data controls

- Inventory structured/unstructured data, objects, databases, snapshots, analytics, logs, caches, indexes, AI stores, backups, exports, and replicas.
- Classify by sensitivity, regulation, contract, business value, and effect on people.
- Minimize collection, fields, retention, copies, locations, access, sharing, and training use.
- Use resource policies, identity, network paths, encryption, masking/tokenization, DLP, and monitoring.
- Protect metadata and backups; prevent public access and cross-tenant/account sharing unless approved.
- Test retention, legal hold, export, correction, deletion, backup expiration, and provider/subprocessor deletion.

Data residency is more than a region selector: Consider primary storage, replicas, backups, logs, support, subprocessors, telemetry, disaster recovery, administration, and lawful government access.

9. Encryption, Keys, Certificates, and Secrets

Cryptography fails when keys, secrets, certificates, algorithms, and permissions are poorly managed.

9.1 Key management

- Define provider-managed, customer-managed, customer-provided, or external-key choices by risk and obligation.
- Separate key administration, key use, cloud administration, and audit where practical.
- Control creation, import, backup, rotation, version, disablement, deletion delay, recovery, escrow, and destruction.
- Restrict key policies and cross-account grants; monitor every administrative and cryptographic use.
- Plan loss, compromise, region failure, provider exit, and encrypted-backup restoration.

9.2 Secrets and certificates

- Use approved secret managers; never place secrets in source, images, logs, tickets, chat, IaC state, or user files.
- Prefer short-lived credentials and automatic rotation; inventory owner, purpose, scope, last use, expiration, and dependencies.
- Automate certificate issuance/renewal with controlled trust, protect private keys, detect expiry and unauthorized certificate creation.

10. Logging, Monitoring, and Detection

Cloud evidence is useful when the right control-plane, data-plane, workload, identity, and application events are enabled and reviewed.

10.1 Logging design

- Define required events before deployment: administrative, identity, policy, data access, network, workload, application, database, key, storage, security, support, and provider events.
- Enable organization/tenant-wide and region-wide coverage; account for new accounts/services and services that require separate data-event settings.
- Centralize to a protected security account, restrict alteration/deletion, use time synchronization and integrity controls, and retain by risk/obligation.
- Normalize identity, resource, action, result, source, location, session, request ID, and time without losing raw evidence.
- Monitor logging disablement, exclusions, retention change, new privileged actions, public exposure, key/secret events, and anomalous data access.

10.2 Evidence limitations

- Provider logs may be delayed, sampled, optional, extra-cost, region-specific, or unavailable after short retention.
- Encryption limits network content visibility; application and identity context become more important.
- Validate that alerts create investigated cases and corrective action—not only dashboards.

11. Vulnerability, Patch, and Exposure Management

Cloud exposure changes continuously through configuration, code, images, dependencies, identities, and provider services.

11.1 Continuous exposure management

- Inventory internet-facing resources, attack paths, identities, software, images, packages, APIs, storage, databases, functions, and third-party connections.
- Use provider advisories, vulnerability feeds, posture/configuration rules, authenticated workload scans, image/dependency scans, secret scans, and penetration tests where authorized.
- Prioritize exploitability, internet reachability, privilege, sensitive data, business criticality, compensating controls, and active threat—not score alone.
- Patch or mitigate infrastructure, OS, runtime, application, container, function, dependency, appliance, and managed-service customer actions.
- Track provider-responsible flaws and service notices; verify customer configuration and version choices.
- Retest correction and measure population coverage, time, exceptions, and recurrence.

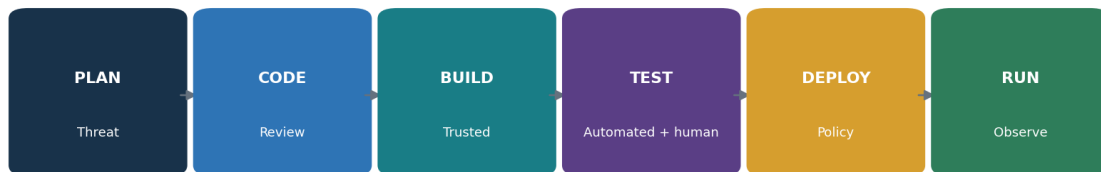
12. Compute, Storage, Database, and Endpoint Security

Each managed service removes some operating work but creates configuration and integration responsibilities.

Resource	Security focus	Evidence
Virtual machines	Images, patching, hardening, EDR, disks, metadata, admin path	inventory, image provenance, config/scan, agent coverage
Object storage	Public access, policies, encryption, versioning, retention, logging	effective policy, access logs, lifecycle, public-block settings
Managed database	Network, identity, admin, encryption, backups, audit, version	config export, users/roles, logs, restore test, maintenance
Block/file storage	Attachment, encryption, snapshots, sharing, backup, deletion	inventory, policies, snapshots, restore/deletion records
Managed desktop/endpoint	Identity, device posture, apps, data, sessions, logging	enrollment, policy, access, events, wipe/termination tests
Marketplace image/service	Publisher, provenance, permissions, updates, data, contract	approval, version, SBOM/advisory, scan, supplier evidence

13. Application Security and DevSecOps

Cloud applications inherit risk from design, code, dependencies, pipelines, identities, APIs, and managed services.



DevSecOps connects secure design, pipelines, deployment, and runtime evidence

Figure 5. Cloud DevSecOps flow

13.1 Secure delivery

- Threat model trust boundaries, data, abuse cases, identity, tenant isolation, provider dependencies, resilience, and failure behavior.
- Use code review, dependency/SBOM, secrets, SAST, IaC, container, API, DAST, and manual testing appropriate to risk.
- Protect source, branches, commits, runners, build systems, artifacts, registries, signing keys, deployments, and production approvals.
- Use short-lived pipeline identity, separation of duties, protected environments, signed provenance, immutable artifacts, and rollback.
- Deploy observability, safe error handling, rate limits, input/output controls, and incident hooks.
- Track vulnerabilities and exceptions to verified remediation and retest.

14. Infrastructure as Code and Policy as Code

Infrastructure and policy as code make cloud decisions repeatable, reviewable, testable, and scalable.

14.1 IaC controls

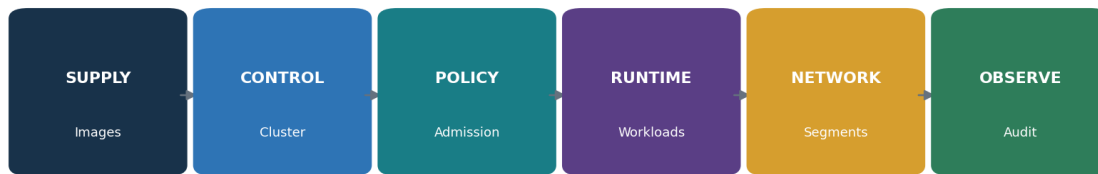
- Use approved modules, pinned versions/providers, trusted registries, code ownership, peer review, branch protection, and signed releases where appropriate.
- Scan code and plan for insecure configuration, secrets, risky dependencies, public exposure, privilege, encryption, logging, and resilience.
- Protect state files, plan output, credentials, backends, locks, drift information, and CI logs.
- Require plan review and approval before production apply; restrict direct console changes and detect drift.
- Test rollback, deletion protection, import, migration, and failure behavior.

14.2 Policy as code

- Use preventive guardrails for prohibited states and detective policies for conditions requiring investigation.
- Test allowed, denied, exception, missing-data, and service-change cases.
- Version rule, owner, rationale, scope, severity, effective date, mapping, exception, and rollback.
- Never enable broad automated remediation without dry-run, blast-radius review, approval, logging, and recovery.

15. Containers and Kubernetes

Kubernetes distributes responsibility across provider control plane, cluster configuration, nodes, images, workloads, network, and identity.



Container security spans supply chain, control plane, workload, and runtime

Figure 6. Kubernetes security layers

15.1 Cluster controls

- Inventory clusters, versions, owners, workloads, namespaces, nodes, registries, identities, data, ingress, and provider responsibility.
- Secure API access, federation, RBAC, service accounts, workload identity, admission, audit logs, and emergency access.
- Use trusted minimal signed images, vulnerability/SBOM checks, non-root execution, read-only filesystems, dropped capabilities, resource limits, and secret managers.
- Apply namespace and network segmentation, egress control, encryption, storage protection, backups, policy enforcement, and runtime detection.
- Patch supported cluster/node versions and test upgrades, autoscaling, recovery, and policy compatibility.

16. Serverless, APIs, and Event-Driven Services

Serverless and event-driven systems reduce host management but increase identity, event, dependency, and observability concerns.

16.1 Serverless controls

- Inventory function, owner, runtime, source, deployment package, dependencies, triggers, destinations, role, secrets, network, data, and retention.
- Use one least-privilege execution role per purpose; prevent confused-deputy and cross-account abuse.
- Validate and authenticate events, constrain recursion/concurrency, enforce timeouts/limits, and handle poison messages and retries safely.
- Scan code/dependencies/IaC, pin runtime and layers, protect deployment, and remove unused functions/versions.
- Log invocation, identity, event metadata, error, destination, and administrative changes while minimizing sensitive content.

16.2 API security

- Inventory every API/version/environment and owner; use gateways, authentication, authorization, schema validation, quotas, rate limits, TLS, safe errors, and logging.
- Test object/function authorization, token validation, mass assignment, injection, SSRF, business logic, inventory, and third-party integrations.
- Protect API keys and webhooks, rotate secrets, sign events, and validate replay resistance.

17. SaaS Security and Business Applications

SaaS security depends heavily on tenant configuration, identity, data use, integrations, endpoints, and provider evidence.

17.1 SaaS review

- Business owner, purpose, users, data, locations, subprocessors, AI/training use, integrations, criticality, recovery, contract, renewal, and exit.
- SSO/MFA, roles, administrators, guests, support access, sessions, sharing, external collaboration, OAuth apps, API tokens, and access reviews.
- Retention, deletion, export, legal hold, encryption, customer keys where available, DLP, labels, audit logs, alerts, and e-discovery.
- Provider SOC/ISO/CSA assurance scope, incidents, vulnerability practices, continuity, availability, subprocessors, and change notice.
- Configuration baseline, continuous drift checks, risky application consent, data sharing, inactive users, and license/account reconciliation.

SaaS blind spot: Procurement approval is not secure operation. Recheck tenant settings, applications, roles, sharing, retention, and provider changes throughout the relationship.

18. Multi-Cloud, Hybrid Cloud, and Portability

Multi-cloud and hybrid designs can reduce or increase risk depending on real operational capability.

18.1 Common challenges

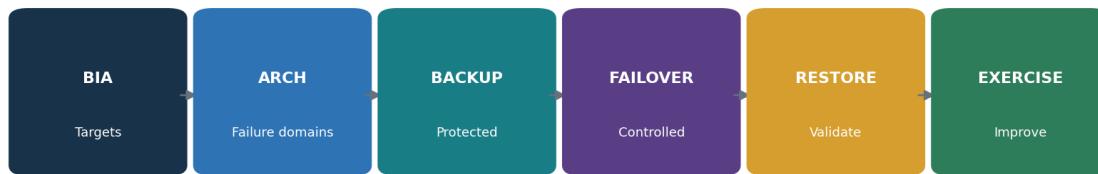
- Different identity, policy, resource, network, encryption, logging, tagging, severity, region, and responsibility models.
- Inconsistent inventories and duplicated security tooling that create gaps and alert overload.
- Cross-cloud trust, data transfer, egress, DNS, routing, certificates, secrets, time, and incident coordination.
- Shared providers and technologies that create hidden concentration despite multiple clouds.
- Portability claims that fail because of proprietary services, data volume, formats, dependencies, skills, time, and cost.

18.2 Strategy

- Define a provider-neutral minimum control standard and map it to provider-native implementation/evidence.
- Centralize only what can be operated reliably; preserve provider-specific security depth.
- Test identity failure, connectivity loss, region failure, provider outage, data export, rebuild, and exit.
- Use diversity when it reduces a credible correlated failure and teams can safely operate it.

19. Resilience, Backup, and Disaster Recovery

Cloud resilience requires business targets, architecture, protected recovery data, and tested end-to-end restoration.



Availability claims require end-to-end recovery tests against business targets

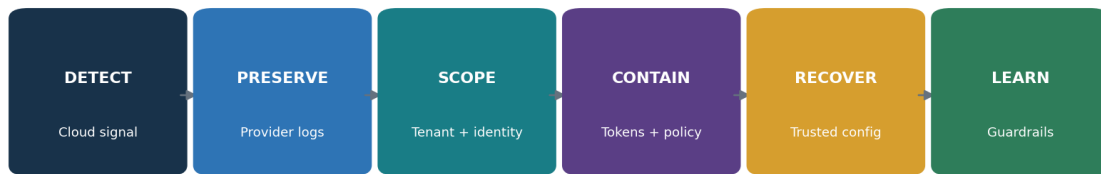
Figure 7. Cloud resilience and recovery

19.1 Resilience design

- Perform BIA; define critical services, minimum output, MTPD/MAO, RTO, RPO, dependencies, capacity, and acceptance criteria.
- Select zones, regions, accounts, providers, failover, queues, retries, circuit breakers, graceful degradation, capacity, and manual workarounds.
- Protect backups/snapshots/configuration/code/keys with separation, immutability or offline control, access segregation, retention, and monitoring.
- Document recovery order for identity, networking, DNS, keys, data, platform, application, integrations, monitoring, and users.
- Exercise realistic failure, corruption, identity compromise, ransomware, provider outage, and supplier dependency scenarios.

20. Cloud Incident Response and Forensics

Cloud incident response depends on provider evidence, control-plane identity, safe automation, and shared duties.



Cloud incident response depends on control-plane evidence and safe identity recovery

Figure 8. Cloud incident workflow

20.1 Prepare

- Cloud-specific playbooks, tenant/account inventory, diagrams, identity and key recovery, provider contacts, support plans, contracts, and out-of-band access.
- Central protected logs with enough retention, provider/API collection methods, snapshots, evidence account, clean administration, and trained roles.
- Preapproved isolation, token revocation, policy restriction, key rotation, network quarantine, workload snapshot, and account lockdown actions.

20.2 Respond

- Preserve identity, audit, API, network, data, workload, key, storage, application, billing, and support evidence.
- Scope tenant/account/project, region, identity, role, token, key, resource, data, time, automation, integration, and supplier.
- Secure trusted administration; revoke sessions/tokens; remove unauthorized roles/apps/rules; rotate secrets in dependency order.
- Restore from trusted code/configuration/data, validate security and business function, reconnect in phases, and monitor recurrence.
- Coordinate provider, customers, insurers, counsel, authorities, and subprocessors under approved obligations.

21. Privacy, Legal, Contract, and Data Residency

Cloud privacy and compliance follow the principles of processing, responsibility, contract, geography, and evidence.

21.1 Privacy and legal review

- Identify controller/processor or equivalent roles, purpose, authority/legal basis, people, data, sensitivity, rights, retention, location, transfer, and government-access concerns.
- Map provider and every relevant subprocessor, service region, support, telemetry, backup, AI use, and deletion path.
- Contract for security, confidentiality, purpose limitation, subprocessor duties, assistance, incident notice, evidence/audit, resilience, return/deletion, and change.
- Test access, correction, export, deletion, retention, legal hold, backup behavior, sharing, consent, and tenant controls.

Framework	Cloud connection	Caution
SOC 2	Provider system, criteria, period, tests, exceptions, CUECs, subservice organizations	Customer must implement CUECs and tenant controls
ISO/IEC 27001	ISMS scope, cloud use, suppliers, access, operations, incidents, continuity	Certificate scope may exclude a service or location
PCI DSS v4.0.1	CDE scope, cloud provider responsibility, segmentation, evidence, incident duties	Provider compliance does not make customer compliant
HIPAA	Business associate, agreement, risk analysis, safeguards, contingency and incidents	Legal applicability depends on facts
GDPR	Processor terms, security, transfers, rights, breaches, deletion, subprocessors	Roles and transfer mechanisms need legal analysis
NIST RMF/800-53	Control allocation, implementation, assessment, authorization, monitoring	Tailor to service and inherited controls
CSA CCM v4.1	Cloud-specific control objectives and CAIQ assurance	Mapping is not automatic compliance

22. CSA Cloud Controls Matrix v4.1 Domains

CSA CCM v4.1 organizes 207 cloud control objectives across 17 domains.

Code / domain	Purpose
A&A — Audit & Assurance	Independent and internal assurance, assessment planning, evidence, findings, and audit coordination.
AIS — Application & Interface Security	Secure application design, APIs, development, testing, deployment, and interface protection.
BCR — Business Continuity Management & Operational Resilience	Continuity, recovery objectives, backups, exercises, dependencies, and resilient service delivery.
CCC — Change Control & Configuration Management	Approved configuration baselines, secure changes, inventories, testing, rollback, and drift control.
CEK — Cryptography, Encryption & Key Management	Cryptographic policy, keys, certificates, secrets, algorithms, rotation, custody, and destruction.
DCS — Datacenter Security	Physical facilities, environmental controls, equipment, media, access, monitoring, and disposal.
DSP — Data Security & Privacy Lifecycle Management	Data inventory, classification, minimization, use, sharing, retention, deletion, privacy, and protection.
GRC — Governance, Risk & Compliance	Policy, accountability, risk management, legal obligations, oversight, reporting, and improvement.
HRS — Human Resources	Screening, agreements, awareness, role changes, termination, sanctions, and workforce responsibilities.
IAM — Identity & Access Management	Identity lifecycle, authentication, authorization, privilege, federation, service identities, and access review.
IPY — Interoperability & Portability	Standards, interfaces, data export, migration, dependency transparency, and exit capability.
IVS — Infrastructure & Virtualization Security	Compute, networks, virtualization, containers, hosts, images, segmentation, and workload isolation.
LOG — Logging & Monitoring	Event generation, central collection, time, protection, retention, detection, review, and alert response.
SEF — Security Incident Management, E-Discovery & Cloud Forensics	Incident plans, reporting, evidence, investigation, provider cooperation, recovery, and learning.
STA — Supply Chain Management, Transparency & Accountability	Provider and subprovider risk, contracts, ownership, provenance, monitoring, incidents, and exit.
TVM — Threat & Vulnerability Management	Threat awareness, testing, exposure, vulnerabilities, remediation, exceptions, and verification.
UEM — Universal Endpoint Management	Management and protection of endpoints that access, administer, or process cloud services and data.

22.1 How to use CCM and CAIQ

- Select the exact CCM v4.1 source and record release/date.
- Determine provider, customer, or shared applicability for each relevant control objective.
- Use CAIQ supplier answers as assertions that require risk-based evidence validation.
- Map controls to architecture, owner, implementation, evidence, test, finding, and remediation.
- Use Implementation and Auditing Guidelines where licensed/available, while tailoring to service and risk.
- Do not claim CSA STAR level or certification unless the exact registry entry and scope support it.

23. Cloud Assurance and Provider Evidence

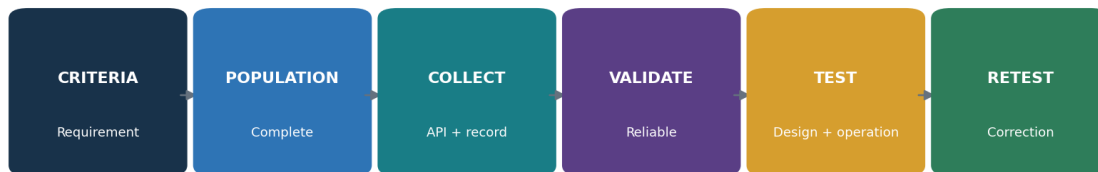
Provider assurance reduces uncertainty only when scope and customer responsibility match the actual use.

Artifact	Review
SOC 2 Type 2	Entity/service, criteria, period, opinion, tests, exceptions, CUECs, subservice organizations, subsequent events
ISO certificate	Organization, service/location scope, standard version, certification body, accreditation, dates, status
CSA STAR / CAIQ	Registry level, CCM/CAIQ version, exact service/entity, answers, evidence, date
Penetration test	Scope, date, tester, methodology, exclusions, findings, correction, retest
Architecture/responsibility	Provider/customer boundary, tenant isolation, admin path, data, subproviders, control ownership
Resilience evidence	Architecture, dependencies, RTO/RPO, exercises, actual results, failures, correction
Vulnerability/development	Disclosure, secure SDLC, SBOM, scanning/testing, patch targets, advisories, end-of-life
Contract / SLA	Security, privacy, notice, evidence, availability, support, change, exit, remedies

Evidence ladder: A questionnaire is useful for discovery. Confidence increases through relevant documents, independent assurance, technical testing, observation, complete populations, and verified remediation.

24. Assessment, Evidence Testing, and Metrics

Cloud assessment joins exact criteria, complete API populations, reliable evidence, human judgment, and retesting.



Cloud assurance needs traceable configuration, event, and process evidence

Figure 9. Cloud evidence-testing chain

24.1 Test method

- Define requirement, provider/service, tenant/account, region, resource types, period, data, environment, and customer/provider allocation.
- Identify complete population using authoritative APIs and reconcile to independent inventory/billing/IaC/identity sources.
- Collect configuration, policy, event, process, contract, and human evidence with time, source, version, query, permissions, and limitations.
- Test design and operation; use full-population automation where reliable and defensible sampling where necessary.
- Validate effective permissions and inherited/shared controls—not only intended settings.
- Write condition, population, risk, cause, action, owner, date, interim control, and retest.

Metric	Example
Owned-resource coverage	Active resources with valid owner ÷ active resources
Public exposure	Internet-reachable resources by approved/unapproved status and criticality
MFA / privilege coverage	Privileged identities with required MFA/JIT ÷ privileged identities
Logging coverage	In-scope accounts/services sending required logs ÷ in-scope accounts/services
Encryption/key compliance	Sensitive resources meeting required key policy ÷ sensitive resources
IaC coverage	Production resources managed by approved code ÷ production resources
Finding age	Open days by severity, exploitability, exposure, owner, and exception
Recovery achievement	Representative tests meeting full-service RTO and RPO ÷ tests

25. AI Services and Emerging Cloud Risk

Cloud AI services add model, data, agent, plugin, provider-chain, and rapidly changing feature risk.

25.1 AI cloud assessment

- Approved use case, decision impact, users, prohibited uses, human oversight, and expected failure handling.
- Prompts, uploads, outputs, embeddings, indexes, fine-tunes, logs, feedback, retention, deletion, location, transfer, and training use.
- Model/provider/version, hosting, identity, permissions, tools/agents/plugins, data sources, networks, secrets, and subprocessors.
- Prompt injection, data leakage, tool misuse, model abuse, unsafe output, content filters, rate limits, monitoring, and red teaming.
- Accuracy, bias, robustness, drift, explainability, evaluation set, acceptance threshold, change notice, and reevaluation.
- IP/licensing, privacy, security, incident, evidence, portability, export, deletion, and provider exit.

Emerging does not remove basic controls: AI services still require inventory, ownership, identity, least privilege, data governance, secure development, logging, incident response, supplier management, resilience, and verified deletion.

26. Open-Source Tools

Open-source tools support inventory, posture, IaC, Kubernetes, runtime, secret, and finding evidence.

Tool	Purpose
Prowler	Cloud security posture and compliance assessment
ScoutSuite	Multi-cloud security configuration review
Steampipe	SQL queries and dashboards across cloud APIs
Cloud Custodian	Cloud governance and policy automation
Checkov	Infrastructure-as-code and configuration scanning
Trivy	Images, repositories, dependencies, secrets, Kubernetes, and IaC checks
tfsec	Terraform static security analysis
Terrascan	Policy-based IaC scanning
OpenTofu	Open-source infrastructure-as-code provisioning
Open Policy Agent	General policy-as-code decisions
Kyverno	Kubernetes-native policy management
kube-bench	Kubernetes CIS Benchmark checks
kube-hunter	Kubernetes exposure discovery
Falco	Cloud-native runtime security detection
Gitleaks	Secret detection in source and history
TruffleHog	Verified secret discovery across repositories and storage
Wazuh	Endpoint, workload, file-integrity, log, and alert monitoring
DefectDojo	Finding intake, deduplication, remediation, and retest

Authorization and cost safety: Use tools only on approved cloud accounts, tenants, clusters, repositories, data, and networks. Start read-only or dry-run. Protect credentials and reports. Automated remediation can delete data, interrupt service, create cost, or expand access; require review, approval, rollback, and logging.

26.1 Prowler

Purpose: Cloud security posture and compliance assessment. Official project: [Prowler](#)

Safe quick start: Use a read-only lab role, choose the correct cloud provider and framework, run a limited assessment, validate the findings, correct them, and rerun.

Retain: authority, account/region/scope, role/permissions, tool/version, policy/query, source data, date, population, result, analyst validation, limitation, finding, action, and retest. Remove temporary credentials and protect output.

26.2 ScoutSuite

Purpose: Multi-cloud security configuration review. Official project: [ScoutSuite](#)

Safe quick start: Create least-privilege read-only lab credentials, scan only approved accounts, protect the local report, validate findings, and remove credentials.

Retain: authority, account/region/scope, role/permissions, tool/version, policy/query, source data, date, population, result, analyst validation, limitation, finding, action, and retest. Remove temporary credentials and protect output.

26.3 Steampipe

Purpose: SQL queries and dashboards across cloud APIs. Official project: [Steampipe](#)

Safe quick start: Configure a lab plugin with read-only access, run a narrow inventory query, compare results to policy, and save query/version evidence.

Retain: authority, account/region/scope, role/permissions, tool/version, policy/query, source data, date, population, result, analyst validation, limitation, finding, action, and retest. Remove temporary credentials and protect output.

26.4 Cloud Custodian

Purpose: Cloud governance and policy automation. Official project: [Cloud Custodian](#)

Safe quick start: Write a lab policy in dry-run or reporting mode, test selection carefully, peer-review, add approval gates, and enable actions only after authorization.

Retain: authority, account/region/scope, role/permissions, tool/version, policy/query, source data, date, population, result, analyst validation, limitation, finding, action, and retest. Remove temporary credentials and protect output.

26.5 Checkov

Purpose: Infrastructure-as-code and configuration scanning. Official project: [Checkov](#)

Safe quick start: Scan a training repository, review exact policy and resource, validate false positives, correct code, document exceptions, and rescan.

Retain: authority, account/region/scope, role/permissions, tool/version, policy/query, source data, date, population, result, analyst validation, limitation, finding, action, and retest. Remove temporary credentials and protect output.

26.6 Trivy

Purpose: Images, repositories, dependencies, secrets, Kubernetes, and IaC checks. Official project: [Trivy](#)

Safe quick start: Scan an authorized training repository or image, validate findings, remediate or approve exceptions, and rescan in CI.

Retain: authority, account/region/scope, role/permissions, tool/version, policy/query, source data, date, population, result, analyst validation, limitation, finding, action, and retest. Remove temporary credentials and protect output.

26.7 tfsec

Purpose: Terraform static security analysis. Official project: [tfsec](#)

Safe quick start: Run against a lab Terraform folder, inspect rule logic and context, correct insecure settings, suppress only with approved rationale, and rerun.

Retain: authority, account/region/scope, role/permissions, tool/version, policy/query, source data, date, population, result, analyst validation, limitation, finding, action, and retest. Remove temporary credentials and protect output.

26.8 Terrascan

Purpose: Policy-based IaC scanning. Official project: [Terrascan](#)

Safe quick start: Scan approved Terraform or Kubernetes examples, review policies and severity, correct, and retain before-and-after results.

Retain: authority, account/region/scope, role/permissions, tool/version, policy/query, source data, date, population, result, analyst validation, limitation, finding, action, and retest. Remove temporary credentials and protect output.

26.9 OpenTofu

Purpose: Open-source infrastructure-as-code provisioning. Official project: [OpenTofu](#)

Safe quick start: Use a sandbox account, pin providers/modules, review the plan, require approval before apply, protect state and secrets, and destroy lab resources.

Retain: authority, account/region/scope, role/permissions, tool/version, policy/query, source data, date, population, result, analyst validation, limitation, finding, action, and retest. Remove temporary credentials and protect output.

26.10 Open Policy Agent

Purpose: General policy-as-code decisions. Official project: [Open Policy Agent](#)

Safe quick start: Write a small lab policy, test allow/deny and error cases, peer-review changes, log decisions, and preserve human exception authority.

Retain: authority, account/region/scope, role/permissions, tool/version, policy/query, source data, date, population, result, analyst validation, limitation, finding, action, and retest. Remove temporary credentials and protect output.

26.11 Kyverno

Purpose: Kubernetes-native policy management. Official project: [Kyverno](#)

Safe quick start: Apply an audit-mode policy in a lab cluster, review affected resources, test exceptions, then enforce only after workloads are ready.

Retain: authority, account/region/scope, role/permissions, tool/version, policy/query, source data, date, population, result, analyst validation, limitation, finding, action, and retest. Remove temporary credentials and protect output.

26.12 kube-bench

Purpose: Kubernetes CIS Benchmark checks. Official project: [kube-bench](#)

Safe quick start: Run in an authorized lab cluster, confirm benchmark/version and managed-service responsibility, validate results, correct, and rerun.

Retain: authority, account/region/scope, role/permissions, tool/version, policy/query, source data, date, population, result, analyst validation, limitation, finding, action, and retest. Remove temporary credentials and protect output.

26.13 kube-hunter

Purpose: Kubernetes exposure discovery. Official project: [kube-hunter](#)

Safe quick start: Use only an isolated lab cluster with written authorization, start with passive discovery, validate exposure, correct, and retest.

Retain: authority, account/region/scope, role/permissions, tool/version, policy/query, source data, date, population, result, analyst validation, limitation, finding, action, and retest. Remove temporary credentials and protect output.

26.14 Falco

Purpose: Cloud-native runtime security detection. Official project: [Falco](#)

Safe quick start: Deploy in a lab, generate a harmless test event, confirm telemetry and alerting, tune with version control, and document coverage limits.

Retain: authority, account/region/scope, role/permissions, tool/version, policy/query, source data, date, population, result, analyst validation, limitation, finding, action, and retest. Remove temporary credentials and protect output.

26.15 Gitleaks

Purpose: Secret detection in source and history. Official project: [Gitleaks](#)

Safe quick start: Scan an authorized training repository, verify each finding, revoke exposed test secrets, remove safely, add prevention, and rescan.

Retain: authority, account/region/scope, role/permissions, tool/version, policy/query, source data, date, population, result, analyst validation, limitation, finding, action, and retest. Remove temporary credentials and protect output.

26.16 TruffleHog

Purpose: Verified secret discovery across repositories and storage. Official project: [TruffleHog](#)

Safe quick start: Use a synthetic lab repository, protect output, validate detector behavior, rotate affected credentials, and document cleanup.

Retain: authority, account/region/scope, role/permissions, tool/version, policy/query, source data, date, population, result, analyst validation, limitation, finding, action, and retest. Remove temporary credentials and protect output.

26.17 Wazuh

Purpose: Endpoint, workload, file-integrity, log, and alert monitoring. Official project: [Wazuh](#)

Safe quick start: Enroll a lab workload, trigger a harmless event, verify collection and response, document coverage, and protect results.

Retain: authority, account/region/scope, role/permissions, tool/version, policy/query, source data, date, population, result, analyst validation, limitation, finding, action, and retest. Remove temporary credentials and protect output.

26.18 DefectDojo

Purpose: Finding intake, deduplication, remediation, and retest. Official project: [DefectDojo](#)

Safe quick start: Import safe lab results, validate duplicates and severity, assign owners/dates, attach evidence of correction, and close after retest.

Retain: authority, account/region/scope, role/permissions, tool/version, policy/query, source data, date, population, result, analyst validation, limitation, finding, action, and retest. Remove temporary credentials and protect output.

27. Manager's Cloud Security Playbook

Managers keep cloud speed aligned with ownership, guardrails, evidence, resilience, and risk decisions.

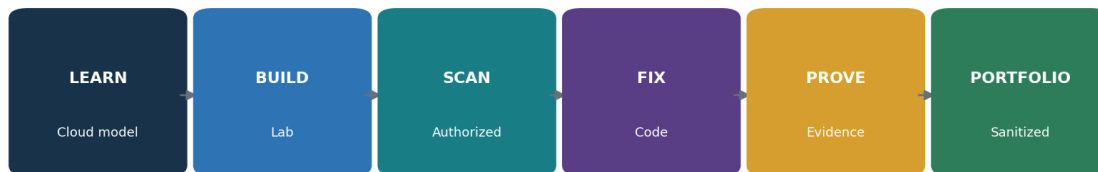
Area	Manager question	Red flag
Inventory	Do all accounts, resources, owners, data, and costs reconcile?	Orphaned tenant or unknown public resource
Responsibility	Is every provider/customer/shared control assigned and evidenced?	Provider report treated as customer proof
Identity	Are admin and workload permissions least, temporary, reviewed, and monitored?	Static keys or standing broad admin
Data	Where is sensitive data, who can use it, and can it be deleted/exported?	Unknown replicas, subprocessors, or AI training
Architecture	Are landing zones, guardrails, logging, networks, keys, and recovery consistent?	Workloads bypass shared foundation
Delivery	Do code, IaC, artifacts, pipelines, and changes have protected provenance?	Direct production changes without trace
Monitoring	Do exposures and alerts create investigation and correction?	Green dashboard with incomplete population
Resilience	Can the complete service meet tested RTO/RPO and provider-failure scenarios?	Backup exists but restore not proven

27.1 Operating rhythm

- Weekly: severe exposures, public resources, privilege changes, logging gaps, critical vulnerabilities, incidents, and cost anomalies with security impact.
- Monthly: account/resource ownership, drift, exceptions, provider advisories, key/secret age, finding remediation, and shadow SaaS/cloud.
- Quarterly: entitlement review, recovery tests, provider assurance changes, concentration, data residency, metrics, and technical debt.
- At every major release/provider change: architecture, responsibility, data, threat, test, rollback, evidence, and risk acceptance.

28. Junior Analyst Career Guide

Junior cloud security analysts create value through accurate inventories, posture review, evidence, remediation, and communication.



Junior analysts demonstrate skill through safe, repeatable cloud evidence

Figure 10. Junior cloud security analyst pathway

28.1 Common roles

- Junior Cloud Security Analyst
- Cloud GRC / Compliance Analyst
- Cloud Security Engineer (associate)
- DevSecOps Analyst
- Cloud Posture Management Analyst
- IAM Analyst
- Security Assurance Analyst
- Cloud Incident Response Analyst

28.2 Typical work

- Maintain account/resource/owner/data inventories and responsibility matrices.
- Review IAM, network, storage, logging, key, backup, SaaS, and provider settings using read-only tools.
- Scan IaC, images, dependencies, Kubernetes, and repositories under approved procedures.
- Validate findings against real context; write clear risk and correction; track retest.
- Gather SOC/ISO/CSA/provider evidence and test customer controls/CUECs.
- Build dashboards with defined populations, sources, limitations, thresholds, and action.
- Support cloud incident timelines, evidence preservation, containment, and recovery.

29. Fictional Laboratory, Thirty-Day Plan, and Interview Preparation

A fictional cloud environment can produce a safe and credible junior portfolio.

Lab rule: Use a sandbox account with spending limits, synthetic data, isolated training workloads, and written authorization. Never scan public targets, employers, providers, or accounts you do not own. Destroy lab resources and remove credentials afterward.

29.1 Portfolio lab

- Create a fictional 75-person company with a customer web app, object storage, managed database, Kubernetes workload, SaaS CRM, identity provider, and AI pilot.
- Build account hierarchy, ownership/tag standard, data flow, shared-responsibility matrix, landing-zone diagram, and risk register.
- Write approved IaC for a small sandbox using OpenTofu; scan with Checkov, Trivy, tfsec, or Terrascan before apply.
- Configure least-privilege roles, MFA, central logs, private storage, encryption, secrets, network controls, backup, and cost limits.
- Run Prowler or ScoutSuite read-only; validate five findings; correct and rerun.
- Use kube-bench/Kyverno/Falco in a lab cluster and document responsibility and limitations.
- Review a synthetic provider SOC/ISO/CSA evidence set and write customer-control gaps.
- Run a cloud identity incident tabletop and a restore test against fictional RTO/RPO.
- Publish only sanitized evidence and label the project fictional, educational, and not a provider certification.

29.2 Thirty-day plan

Days	Focus	Deliverable
1–3	Cloud models, responsibility, governance	Concept map and responsibility matrix
4–6	Accounts, inventory, landing zones	Hierarchy, tags, architecture
7–9	Identity, network, data, crypto	Four control workpapers
10–12	Logging, posture, vulnerability	Read-only assessment and findings
13–15	IaC, policy, DevSecOps	Scanned IaC and corrected code
16–18	Containers, serverless, APIs	Kubernetes and API checklists
19–21	SaaS, hybrid, privacy, provider evidence	SaaS assessment and assurance review
22–24	Resilience and incident response	Restore test and tabletop
25–27	CCM v4.1 and evidence testing	Domain map and five tests
28–30	Portfolio and interviews	Dashboard, manager memo, five STAR stories

29.3 What is shared responsibility?

The provider and customer divide security tasks by service model, feature, contract, and configuration. The exact boundary must be documented and tested.

29.4 IaaS versus PaaS versus SaaS?

IaaS gives the customer more workload responsibility; PaaS manages more runtime; SaaS manages the application platform while the customer still controls users, tenant settings, data, integrations, and endpoints.

29.5 Why is identity critical in cloud?

APIs and control planes allow identities and tokens to create, change, access, or delete resources at scale.

29.6 What is a landing zone?

A reusable cloud foundation for hierarchy, identity, networking, logging, guardrails, shared services, and workload separation.

29.7 CSPM scan versus assessment?

A scan detects configured conditions. An assessment validates criteria, full scope, responsibility, evidence reliability, operating process, exceptions, risk, and retest.

29.8 What is infrastructure as code?

Version-controlled declarative definitions of infrastructure that can be reviewed, tested, deployed, and monitored for drift.

29.9 How do you secure secrets?

Use a managed secret store, short-lived credentials, narrow permissions, rotation, monitoring, and prevention in code, logs, images, and state.

29.10 How do you verify cloud recovery?

Restore the full service from protected sources, measure actual time/data loss, validate security, data, interfaces, performance, and business acceptance.

29.11 What is CSA CCM v4.1?

A cloud control framework with 207 control objectives across 17 domains, paired with CAIQ for provider assurance.

29.12 What makes a good junior analyst?

Careful scope, read-only first steps, reliable evidence, validation, clear writing, secure credential handling, and honest limitations.

30. Templates, Glossary, Index, and References

Reusable work structures, key terms, subject index, and authoritative starting points.

30.1 Cloud inventory and responsibility record

Field	Entry
Provider / tenant / account / region	_____
Service / resource / owner	_____
Purpose / environment / criticality	_____
Data / residency / retention	_____
Identity / privilege / integration	_____
Network / exposure	_____
Provider responsibility	_____
Customer responsibility	_____
Evidence / assessment / findings	_____
Recovery / incident / exit	_____

30.2 Cloud control workpaper

Field	Entry
Requirement / framework / version	_____
Scope / population / responsibility	_____
Architecture / implementation	_____
IaC / policy / configuration	_____
Process / owner / frequency	_____
Evidence source / query / date	_____
Test / result / exceptions	_____
Risk / cause / interim protection	_____
Action / owner / due date	_____
Retest / closure	_____

30.3 Provider assurance review

Field	Entry
Provider/service/entity	_____
Artifact/issuer/period	_____
Scope/regions/criteria	_____
Opinion/certificate status	_____
Tests/exceptions/findings	_____
CUECs / customer duties	_____
Subservice organizations	_____
Subsequent events/changes	_____
Applicability/evidence gaps	_____
Action/risk decision	_____

30.4 Incident and recovery record

Field	Entry
Case/commander/severity	_____
Tenant/accounts/resources	_____
Identity/tokens / keys	_____

Field	Entry
Data/regions/providers	
Timeline/logs/preservation	
Containment/approvals	
Eradication / trusted source	
Restore / RTO / RPO	
Validation/acceptance	
Lessons/action/retest	

30.5 Glossary

Term	Meaning
CAIQ	Consensus Assessments Initiative Questionnaire paired with CSA CCM.
CCM	Cloud Controls Matrix.
Cloud control plane	APIs and services used to administer cloud resources.
CSPM	Cloud security posture management.
Guardrail	Preventive or detective rule constraining cloud use.
IaaS	Infrastructure as a Service.
IaC	Infrastructure as code.
Landing zone	Standard cloud foundation for governance and workloads.
PaaS	Platform as a Service.
Policy as code	Machine-evaluated policy rules stored and governed as code.
RPO	Maximum tolerable data loss measured in time.
RTO	Target time to restore.
SaaS	Software as a Service.
Service principal/workload identity	Nonhuman identity used by software or automation.
Shared responsibility	Allocation of provider and customer security duties.
STAR	CSA Security, Trust, Assurance and Risk program/registry.

30.6 Subject index

Subject	Chapter
AI services	25
Applications / DevSecOps	13
Assessment/evidence	23–24
CSA CCM v4.1	22
Data/privacy	8, 21
Encryption/keys/secrets	9
Identity	6
IaC / policy	14
Incident response	20
Inventory/landing zones	4–5
Kubernetes	15
Logging	10
Manager	27
Network	7
Resilience/recovery	19
SaaS	17
Serverless / APIs	16
Shared responsibility	2
Tools	26
Vulnerability	11

30.7 Official references

- [CSA Cloud Controls Matrix v4.1](#)
- [CSA CCM home](#)
- [CSA STAR resources](#)
- [NIST SP 800-145 — Definition of Cloud Computing](#)
- [NIST SP 800-144 — Public Cloud Security and Privacy](#)
- [NIST SP 800-146 — Cloud Synopsis and Recommendations](#)
- [NIST SP 800-210 — Cloud Access Control](#)
- [NIST Cloud Computing Publications](#)
- [CISA SCuBA Project](#)
- [CISA Cloud Security Technical Reference Architecture](#)
- [CIS Benchmarks](#)
- [CISA Zero Trust Maturity Model](#)
- [OWASP Cloud-Native Application Security Top 10](#)

Final reminder: Cloud providers, services, features, regions, threats, standards, contracts, prices, tools, and configuration recommendations change rapidly. Verify the current provider and authoritative source before implementation, assessment, or risk acceptance.